

Fecha de elaboración: 4 de marzo de 2026

Instituto Politécnico Nacional

Escuela Superior de Cómputo

Informe de servicio de TI

Elaborado por:

Escarcega Hernández Steven Arturo

Hernández Jiménez Irmin

Mariano Reyes Cesar Alberto

Grupo: 7CV4

UA: IT Governance

Profesor(a): Rocío Palacios Solano

Fecha de elaboración: 4 de marzo de 2026

Información del servicio de TI

Nombre del servicio: Gestión de vulnerabilidades

Clave: GV-1

Fecha propuesta de inicio: 4 de febrero de 2026

Fecha propuesta de fin: 12 de junio de 2026.

Nombre del administrador del servicio: Irmin Hernández Jiménez

Antecedentes

En el ámbito de las Tecnologías de la Información, una vulnerabilidad se define como una debilidad en la lógica computacional (por ejemplo, el código) que se encuentra en los componentes de software y hardware y que, cuando se explota, tiene un impacto negativo en la confidencialidad, la integridad o la disponibilidad [1].

Estas brechas pueden existir a nivel de configuración de infraestructura, en fallos de diseño de red o directamente en el código fuente de las aplicaciones, actuando como vectores de entrada que exponen los activos de información.

La criticidad de identificar y gestionar estas debilidades radica en el dinámico panorama de amenazas actual. Cuando una vulnerabilidad no es mitigada a tiempo, crea el escenario propicio para ser explotada por actores maliciosos. Frecuentemente, estas debilidades en los sistemas son la vía principal que permite la inyección y ejecución de código malicioso, facilitando ataques de alto impacto como el secuestro de datos. Esto compromete directamente la triada fundamental de la seguridad de la información: confidencialidad, integridad y disponibilidad.

La ausencia de evaluaciones sistemáticas y periódicas, similares a las metodologías estructuradas en las pruebas de penetración, genera puntos ciegos en la superficie de ataque de la organización.

Justificación técnica del servicio

En las empresas, muchas veces es necesario saber abordar de buena forma las vulnerabilidades que se presenten, pues al estar en continuo desarrollo tecnológico y en la era digital, muchas de las tecnologías presentan distintas vulnerabilidades que podrían alcanzar a tener un impacto crítico si se tiene una ventana de exposición demasiado prolongada, generada por un manejo deficiente o nulo de las vulnerabilidades [2].

En este sentido, algunas de las razones por las que vale la pena un servicio de gestión de vulnerabilidades son:

- Visibilidad de activos: Contar con una funcionalidad que escanee continuamente los activos tecnológicos de la empresa que puedan estar expuestos a vulnerabilidades, manteniendo un registro apropiado de todos los activos que sean utilizados dentro de la empresa.
- Priorización inteligente: Utilizar el Valor de Priorización de Vulnerabilidades (VPR) ayuda a filtrar de forma más inteligente las vulnerabilidades que pueda tener un activo de acuerdo con su rol dentro de la empresa.
- Reducción de la superficie de ataque: Mantener un enfoque preventivo ante posibles vulnerabilidades mediante inspecciones periódicas en código, configuraciones erróneas de infraestructura, software con vulnerabilidades y estaciones de trabajo o servidores con puertos abiertos de forma innecesaria.

Al contar con una gestión continua, permite que los ataques se presenten en menor frecuencia, y con un plan previo si es que se presenta, a diferencia de un enfoque reactivo.

Alcance

Este servicio busca brindar una gestión de vulnerabilidades de: Infraestructura física de red, infraestructura física de servidores, estaciones de trabajo personales,

Fecha de elaboración: 4 de marzo de 2026

estaciones de trabajo compartidas, máquinas virtuales, código hecho por la empresa y configuraciones de la nube.

La gestión se hará de forma automatizada mediante escaneos periódicos para manejar las vulnerabilidades de forma apropiada con un continuo seguimiento y estableciendo niveles de acuerdo del servicio (SLA) para direccionar las vulnerabilidades con el equipo encargado de su remediación.

El servicio en general se limitará a las vulnerabilidades detectadas de forma automatizada, y al registro de las vulnerabilidades detectadas por el equipo de seguridad ofensiva interno de la empresa o por consultoría externa, este servicio no encontrará vulnerabilidades de forma manual (ejemplo, mediante pruebas de penetración).

El servicio implementará automatizaciones que ayude a dar una mejor visibilidad a las vulnerabilidades descubiertas.

Objetivo

Implementar un servicio de gestión de vulnerabilidades que integre el escaneo de activos, código e infraestructura física y virtual, generando reportes y direccionamiento automático con el equipo encargado de la remediación de estos, implementando procesos para la corrección de vulnerabilidades o para asumir riesgos relacionados con las vulnerabilidades encontradas.

Riesgos clave

Descripción del riesgo	Impacto	Probabilidad
Falsos positivos: Las herramientas automatizadas pueden generar un alto volumen de falsos positivos		

saturando a los analistas de ciberseguridad y retrasando la atención de amenazas reales		
Ataques críticos por vulnerabilidades no mitigadas: Que una vulnerabilidad crítica pase desapercibida o no se mitigue a tiempo, permitiendo realizar ataques críticos que comprometan la información u operación del cliente		
Puntos ciegos por limitación del alcance: Como el servicio se limita a la detección automatizada y excluye pruebas de penetración manuales, existe un riesgo de no identificar vulnerabilidades lógicas complejas que requerirían la visión de un especialista externo o pentester		
Incumplimiento de los SLA de remediación: Que el equipo encargado de la		

Fecha de elaboración: 4 de marzo de 2026

remediación no solucione los fallos dentro de los niveles de acuerdo del servicio establecidos, manteniendo una ventada de exposición prolongada		
Activos no identificados: Que existan nuevos activos tecnológicos que sean implementados por otras áreas de la empresa sin notificar al equipo de seguridad. Al no estar en el inventario oficial, las herramientas automatizadas no los evaluarán, dejando puntos ciegos críticos con vulnerabilidades desconocidas		

Definición de indicadores

Nombre del indicador	Tipo	Fórmula

Beneficios esperados

1. Reducción de riesgos de seguridad

La gestión de vulnerabilidades permite identificar y corregir fallas en los sistemas antes de que puedan ser explotadas por atacantes, reduciendo significativamente el riesgo de incidentes de seguridad.

2. Protección de la información

Al detectar debilidades en aplicaciones, redes y sistemas, se protege la confidencialidad, integridad y disponibilidad de la información crítica de la organización.

3. Prevención de incidentes y ataques informáticos

La detección temprana de vulnerabilidades permite aplicar medidas correctivas antes de que se conviertan en un problema mayor, evitando ataques cibernéticos o accesos no autorizados.

4. Cumplimiento de normativas y estándares de seguridad

La implementación de este servicio facilita el cumplimiento de buenas prácticas y estándares internacionales de seguridad, como marcos de referencia de gobierno de TI, seguridad de la información y cumplimientos regulatorios.

5. Mejora continua de la infraestructura tecnológica

El monitoreo constante de vulnerabilidades permite mantener los sistemas actualizados con los últimos parches de seguridad para reducir la superficie de ataque.

6. Mayor confianza en los servicios tecnológicos

La gestión adecuada de vulnerabilidades incrementa la confianza de usuarios, clientes y colaboradores en los sistemas y servicios digitales de la organización.

Planeación a alto nivel

Cronograma a alto nivel

Personal involucrado

Perfil	Número	Tipo de contrato
Responsable de Seguridad de la Información (CISO / Security Manager)	1	Tiempo completo
Analista de Ciberseguridad / Vulnerability Analyst	2	Tiempo completo
Ingeniero de Infraestructura / Sistemas	2	Tiempo completo
QA / Tester de Software	2	Tiempo completo

Justificación económica del servicio de TI

En esta sección se abordará por qué es viable implementar el servicio de TI, desde ver las opciones que ya existen en el mercado hasta los costos involucrados a este servicio.

Estudio de mercado

En el mercado existen diversas herramientas que son relevantes en el contexto de la gestión de vulnerabilidades, vale la pena conocerlas a detalle, saber qué ofrecen, cuáles son sus puntos fuertes y qué limitantes tienen.

Tenable one

Es una plataforma para la gestión de la exposición frente a vulnerabilidades, este producto unifica a otros como Nessus, Tenable.io y Tenable.ad. Tenable one ofrece una visión integral a profundidad de las vulnerabilidades en software, analizando rutas de ataque, identidades y activos en la nube para proporcionar un puntaje de exposición más preciso. [3]

Sus principales limitantes son su alto costo, al integrar muchas herramientas en una sola, además de que al ser varios productos en uno solo, puede ser difícil manejarlo, además que las capacidades de seguimiento a los planes de remediación son menos maduras en comparación a sus capacidades de detección.

Qualys

Es una herramienta estándar basada en la nube para la detección y respuesta frente a vulnerabilidades, ofreciendo funcionalidades como la gestión de activos, gestión y configuración de las vulnerabilidades, remediación de riesgos, detección de amenazas y cumplimiento regulatorio. [4]

Su principal fuerte es que puede funcionar en un escalado masivo sin perder precisión utilizando cloud agents que reportan la información casi en tiempo real. Además, el motor que ofrecen TruRisk es muy bueno para priorizar qué debe de arreglarse primero de acuerdo con las necesidades del negocio.

En sus principales limitantes está que se siente como un sistema heredado que tiende a ser lento para redes de muchos activos, además que, si no usas sus agentes, sus escaneos en masa suelen ser muy lentos frente a la competencia, además que no es tan abierto a integraciones externas para la automatización.

Rapid7

Es otra alternativa para la gestión de vulnerabilidades, aunque también integra múltiples herramientas múltiples herramientas de ciberseguridad como gestión de exposición a ataques, gestión de superficie de ataque e inteligencia contra amenazas. [5]

Fecha de elaboración: 4 de marzo de 2026

Su principal ventaja es la integración y generación de reportes, pues se presenta como una herramienta ideal para que el equipo de seguridad y de TI trabajen sobre el mismo camino. Además de contar una integración de forma nativa con Metasploit.

Entre sus limitantes se encuentra el alto costo, además de contar con un gran número de falsos positivos que deben ser analizados.

Con estas alternativas en mente, lo que se propone en esta propuesta va más allá de implementar una de estas herramientas pues si bien son herramientas potentes para la detección, aún queda en manos de un equipo humano realizar las remediaciones que sean requeridas, alineadas a las prioridades del negocio. El servicio ofrecido integra estas herramientas de forma inteligente para que más allá de tener un panel con una visión de qué está pasando, se cuente con un proceso formal para remediar estas vulnerabilidades.

En la Tabla 1 se muestra un comparativo de las herramientas expuestas en este apartado frente a la alternativa que se plantea en este documento:

Característica	Herramienta de VM individual (tenable, Qualys y rapid7)	Propuesta de servicio	Ventaja económica de la propuesta
Enfoque	Proporcionan la plataforma y las detecciones técnicas	Brindar el ciclo de vida completo de la vulnerabilidad	Se pagará por los resultados y no solo por tener visibilidad de las vulnerabilidades
Alcance en código	Requieren de módulos adicionales para poder integrar de forma nativa el código	Integración directa con herramientas de escaneo de código de repositorios junto con automatizaciones para su gestión	Mayor ahorro en licencias y plugins
Gestión de remediación	El cliente debe dar el seguimiento manualmente o hacer la configuración desde 0 con su gestor de incidencias	Los módulos ya se encontrarán automatizados y preconfigurados para que se asignen las incidencias de acuerdo con el SLA	Reduce el costo de horas y mano de obra para una gestión integral
Seguimientos de SLAs	Solo se muestra si la vulnerabilidad existe o no	Seguimiento continuo, dirección y escalamiento automático con el equipo responsable	Evita problemas y multas asociados con temas regulatorios y aumenta la visibilidad a vulnerabilidades para su seguimiento continuo

Tabla 1. Tabla comparativa de los servicios del mercado y el servicio que se plantea en este trabajo.

Costos de mantenimiento

--

Costos de operación

--

Procedimiento de adquisición

Glosario técnico

Vulnerabilidad: Debilidad en la lógica computacional (software o hardware) que, al ser explotada, impacta negativamente en la seguridad.

Vector de ataque: Vía o método por el cual un actor malicioso puede obtener acceso a un sistema o red para explotar una vulnerabilidad.

Superficie de ataque: El conjunto total de puntos de entrada (activos, configuraciones, puertos) que pueden ser expuestos a posibles ataques.

Tríada de la seguridad: Los tres pilares fundamentales de la seguridad de la información: Confidencialidad, integridad y disponibilidad.

Falso positivo: Resultado de una herramienta automatizada que identifica erróneamente una amenaza o vulnerabilidad inexistente.

Gestión de vulnerabilidades: Ciclo de vida que incluye la identificación, priorización y remediación de fallos en sistemas y aplicaciones.

VPR (Vulnerability Priority Rating): Valor de priorización de vulnerabilidades utilizado para filtrar fallos según el rol del activo en la empresa.

SLA (Service Level Agreement): Niveles de acuerdo del servicio que establecen los tiempos y responsabilidades para la remediación de vulnerabilidades.

Remediación: Proceso de corrección o mitigación de las vulnerabilidades encontradas en los sistemas.

Pruebas de penetración (Pentesting): Evaluaciones de seguridad manuales y sistemáticas para encontrar fallos lógicos complejos, excluidas de la detección automatizada.

Activo tecnológico: Cualquier componente de hardware o software (servidores, estaciones de trabajo, máquinas virtuales) que forma parte de la infraestructura de la empresa.

Fecha de elaboración: 4 de marzo de 2026

Cloud Agents: Agentes ligeros basados en la nube que reportan información de activos en tiempo real.

Puntaje de exposición: Calificación que proporciona una visión integral de qué tan vulnerable es un conjunto de activos frente a amenazas.

Referencias

[1] NIST, «National Vulnerability Database,» NIST, 3 Agosto 2023. [En línea]. Available: <https://nvd.nist.gov/vuln>.

[2] IBM, «¿Qué es la gestión de vulnerabilidades?,» Think, [En línea]. Available: <https://www.ibm.com/mx-es/think/topics/vulnerability-management>. [Último acceso: 5 Marzo 2026].

[3] Tenable Inc., «Tenable one,» Tenable Inc., [En línea]. Available: <https://www.tenable.com/products/tenable-one>. [Último acceso: 16 Marzo 2026].

[4] Qualys Inc., «Enterprise Cyber Risk and Security Agent | Qualys,» Qualys, [En línea]. Available: <https://www.qualys.com/>. [Último acceso: 16 Marzo 2026].

[5] Rapid7, «Rapid7 Managed Cybersecurity: Outpace Attackers,» Rapid7, [En línea]. Available: <https://www.rapid7.com/>. [Último acceso: 17 Marzo 2026].